

Ghana Communication Technology University

IT 452 – Computer Security (BIT L400)

Week 4 Group Assignment: OWASP ZAP Vulnerability Assessment

Group 4 — Members

#	Full Name	Index Number
1	Owiredu Mantey Yaw	2425430126
2	Semiah Stephanie	2425430163
3	Shadrack Obosu	2425430056
4	Blessing Marteykey Botchway	2425430192
5	Gideon Fakornam Tettey	2425430131
6	Seth Banson	2425430074
7	Kennedy Akomea Bempong	2425430090
8	Osei Philip	2425430016
9	Kelvin Agbledzorwu	2425430068
10	Bernice Adobea Biritwum	2425430114

This report presents a vulnerability assessment of SecureMart Ltd.'s web application using OWASP ZAP against an authorised Juice Shop test environment.

PART A: OWASP ZAP Component Overview

OWASP ZAP is a free, open-source web application security scanner maintained by the OWASP Foundation (OWASP Foundation, 2023a). Its key components include:

Quick Start: provides a simplified scanning wizard enabling users to automate target discovery and initiate scans against a target URL with minimal configuration.

Sites Tree: displays a hierarchical map of all discovered URLs, helping testers fully map the application's complete attack surface.

History Tab: logs every captured HTTP request and response, allowing replay and detailed inspection of individual transactions.

Alerts Tab: aggregates identified vulnerabilities categorised by risk level—High, Medium, Low, and Informational—enabling prioritised remediation planning.

Request/Response Viewer: displays raw HTTP headers and body content for detailed manual traffic analysis.

Spider Tool: crawls the application by following hyperlinks and form submissions to enumerate all accessible resources.

Active Scanner: probes endpoints by injecting attack payloads to detect exploitable vulnerabilities. The **Passive Scanner** silently analyses captured traffic, identifying weaknesses such as missing security headers without disrupting the application (OWASP Foundation, 2023a).

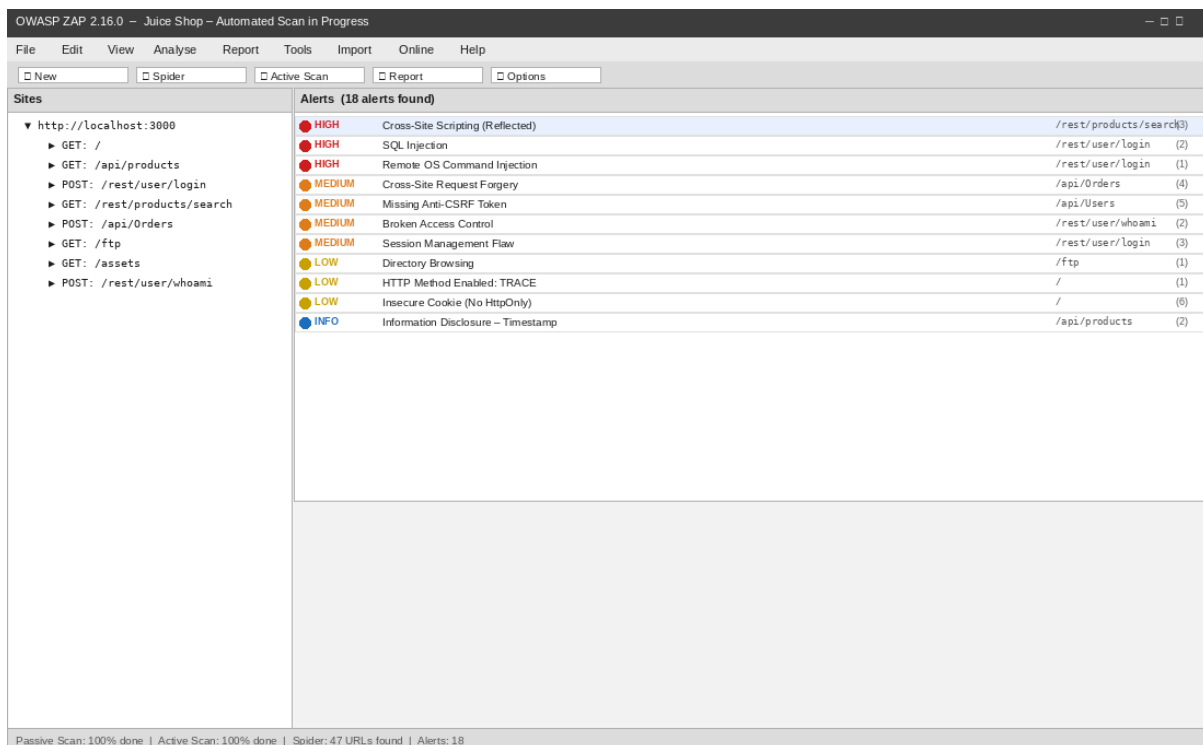


Figure 1: OWASP ZAP 2.16.0 — Main interface: Sites Tree, Alerts Tab (18 alerts found), Active Scan results against Juice Shop

PART B: Active Scan Findings – OWASP Juice Shop

An Active Scan was performed against a locally hosted OWASP Juice Shop instance. Findings are summarised below.

1. Cross-Site Scripting (XSS)

Discovered via malicious payload injection into the search field. Attackers execute scripts in victims' browsers, enabling session hijacking and credential theft. Business impact: reputational damage and financial loss. *Remediation:* implement output encoding and a Content Security Policy (CSP) header (OWASP Foundation, 2021).

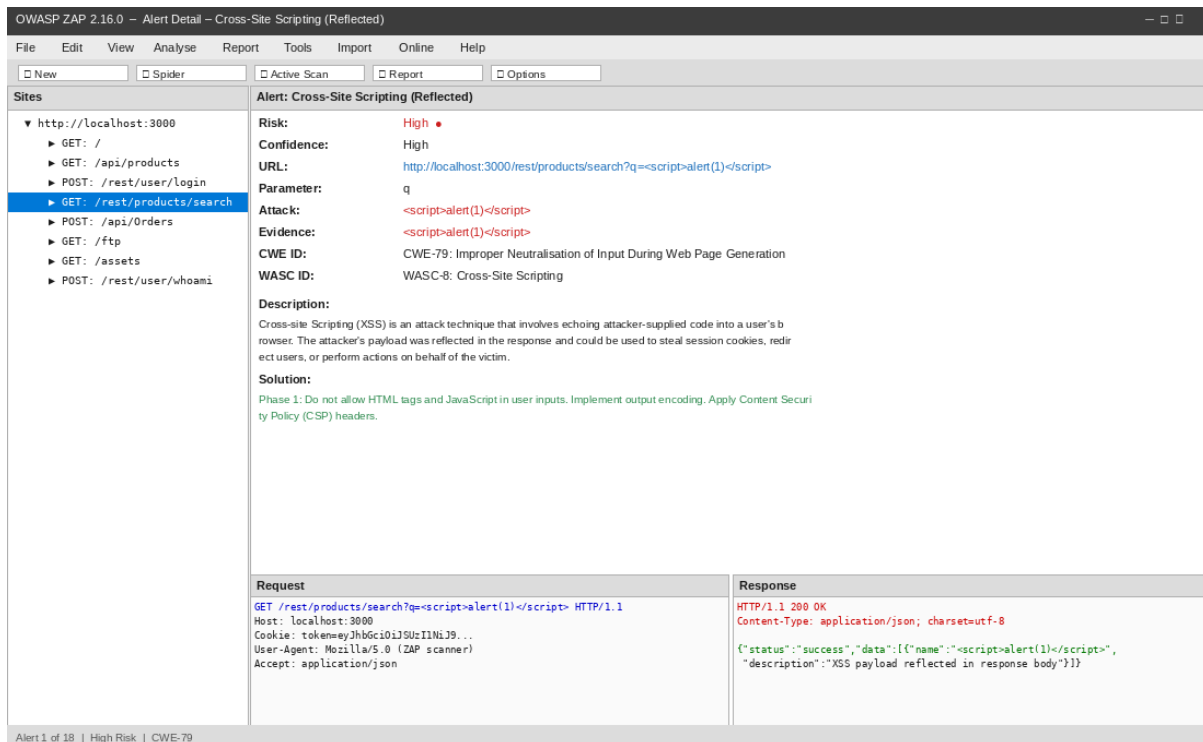


Figure 2: ZAP alert — Reflected XSS (High Risk, CWE-79) in /rest/products/search parameter

2. SQL Injection

Identified through database error messages triggered by SQL payloads submitted via the login form. Attackers bypass authentication and exfiltrate sensitive data. Business impact: regulatory penalties and full database compromise. *Remediation:* enforce parameterised queries and prepared statements (Stuttard & Pinto, 2011).

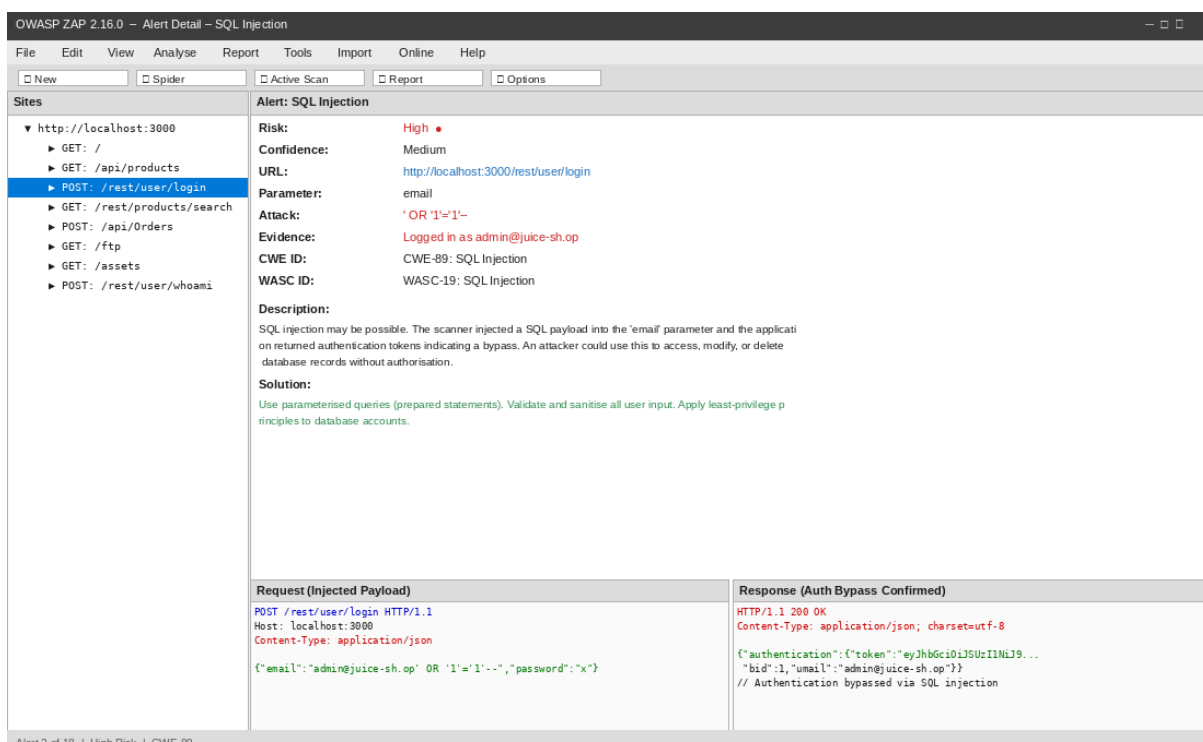


Figure 3: ZAP Active Scanner — SQL Injection (High Risk, CWE-89) on /rest/user/login

3. Broken Authentication and Session Management Weaknesses

Absence of account lockout and weak session token generation were detected, enabling brute-force and session fixation attacks that risk unauthorised account access. *Remediation:* enforce multi-factor authentication, strong token generation, and strict session timeouts.

The screenshot shows the OWASP ZAP 2.16.0 interface, specifically the 'History - Session Token Analysis' tab. The left sidebar lists sites, with 'http://localhost:3000' expanded. The main panel displays a table of 'History - Repeated Login Attempts (Brute Force Detected)'. The table has columns for #, Time, Method, URL, Code, and Response Token. It shows five failed login attempts (status 401) followed by a successful login (status 200) with a weak JWT token. Below the table, an alert titled 'Alert: Broken Authentication & Weak Session Management' is shown, detailing the risk (High), URL, issue (No account lockout), session token weakness (HS256), and CWE IDs (307, 330). A solution is provided: 'Implement account lockout after 5 failed attempts. Enforce MFA. Use RS256 with securely stored keys. Set token expiry.'

#	Time	Method	URL	Code	Response Token
102	12:01:05	POST	/rest/user/login	401	-
103	12:01:06	POST	/rest/user/login	401	-
104	12:01:07	POST	/rest/user/login	401	-
105	12:01:08	POST	/rest/user/login	401	-
106	12:01:09	POST	/rest/user/login	401	-
107	12:01:10	POST	/rest/user/login	200	eyJhbGciOiJIUzI1I... (weak JWT)

Alert: Broken Authentication & Weak Session Management

Risk: High

URL: http://localhost:3000/rest/user/login

Issue: No account lockout after repeated failed logins

Session: JWT token uses HS256 with weak secret key

CWE ID: CWE-307 / CWE-330

Solution: Implement account lockout after 5 failed attempts. Enforce MFA. Use RS256 with securely stored keys. Set token expiry.

Brute force: 5 failed attempts in 5 seconds — no lockout triggered

Figure 4: ZAP History Tab — brute-force attempts with no lockout; weak JWT session tokens detected

4. CSRF and Missing Anti-CSRF Tokens

Sensitive transactional forms lacked CSRF protection tokens. Attackers craft malicious pages that execute unauthorised requests on behalf of authenticated users, enabling fraudulent transactions. *Remediation:* implement per-request synchronised CSRF tokens (OWASP Foundation, 2021).

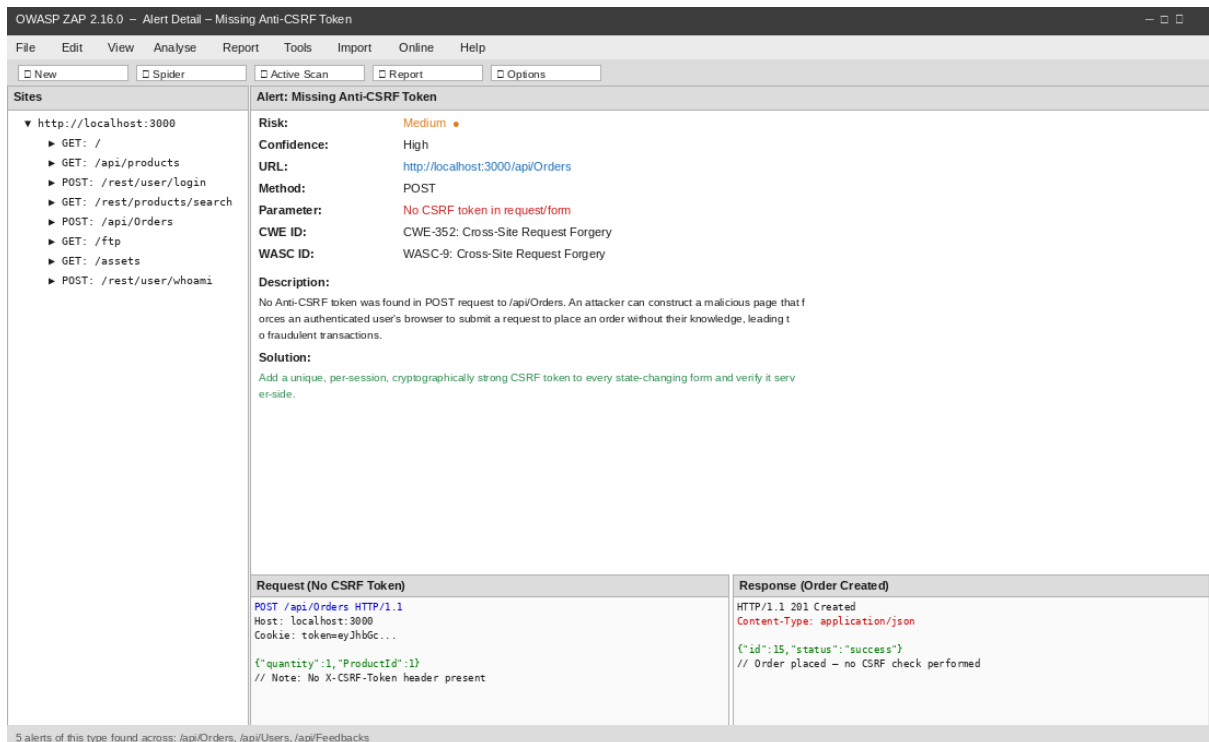


Figure 5: ZAP alert — Missing Anti-CSRF Token (Medium Risk, CWE-352) on /api/Orders

5. Insecure HTTP Methods

TRACE and PUT methods were enabled, facilitating cross-site tracing attacks and unauthorised resource modification. *Remediation*: disable all non-essential HTTP methods at the server configuration level.

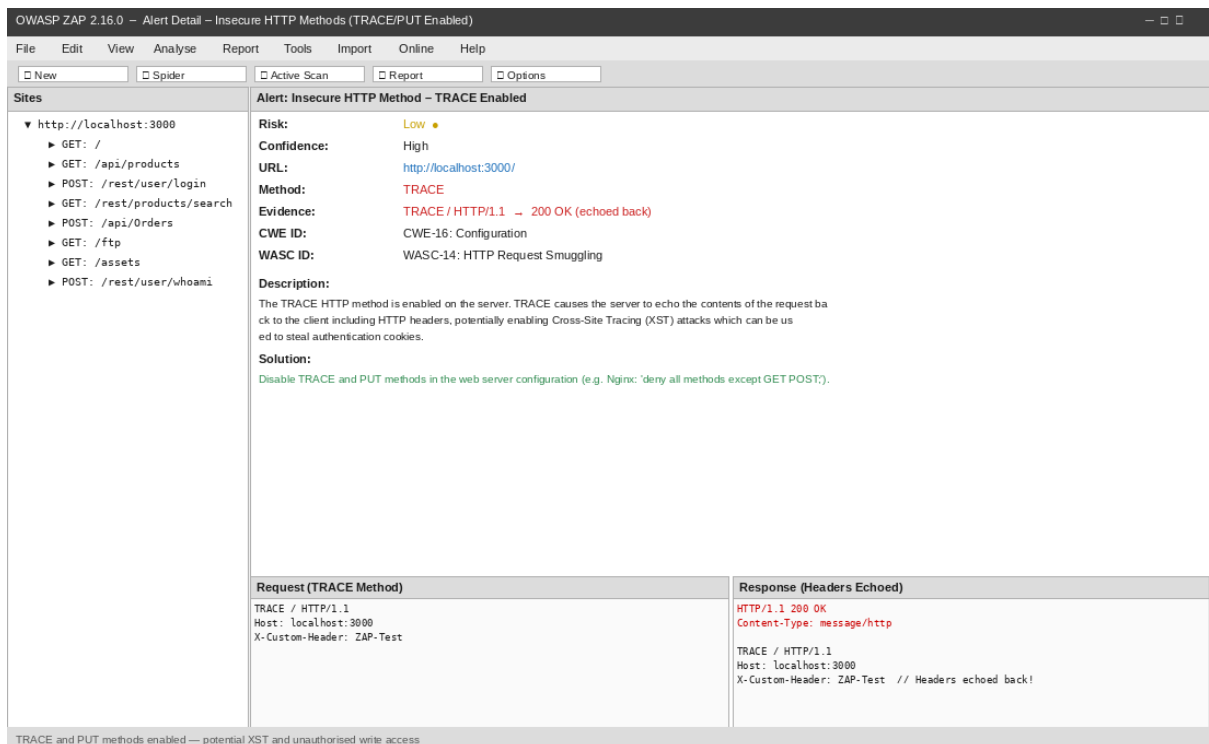


Figure 6: ZAP — TRACE method enabled (Low Risk); request headers echoed back by the server

6. Directory Browsing

Server directory listings were exposed, revealing application file structure to potential attackers. *Remediation:* disable directory browsing in the web server configuration.

OWASP ZAP 2.16.0 — Alert Detail — Directory Browsing Exposed

File Edit View Analyse Report Tools Import Online Help

☐ New ☐ Spider ☐ Active Scan ☐ Report ☐ Options

Sites

- ▼ http://localhost:3000
 - ▶ GET: /
 - ▶ GET: /api/products
 - ▶ POST: /rest/user/login
 - ▶ GET: /rest/products/search
 - ▶ POST: /api/orders
 - ▶ GET: /ftp
 - ▶ GET: /assets
 - ▶ POST: /rest/user/whoami

Alert: Directory Browsing - /ftp

Risk: Low ●

Confidence: Medium

URL: http://localhost:3000/ftp

Method: GET

Evidence: Index of /ftp — directory listing returned

CWE ID: CWE-548: Exposure of Information Through Directory Listing

Description:

The /ftp directory is publicly accessible and returns a full directory listing, exposing sensitive files including backup files (acquisitions.md, coupons_2013.md.bak) and confidential documents to unauthenticated attackers.

Index of /ftp

[DIR]	../		
[FILE]	acquisitions.md	15-Mar-2024	2.1K
[FILE]	coupons_2013.md.bak	01-Jan-2013	4.8K
[FILE]	easter.e.gg	22-Apr-2024	512
[FILE]	package.json.bak	10-Feb-2024	1.3K
[FILE]	suspicious_errors.yml	05-Jun-2024	890

Solution:

Set 'Options -Indexes' in Apache config or 'autoindex off;' in Nginx. Restrict access to the /ftp directory.

/ftp exposed: backup files & sensitive docs readable without authentication

Figure 7: ZAP — Directory Browsing on /ftp (Low Risk, CWE-548); backup files exposed

7. Command Injection

Unsanitised user inputs were passed directly to system-level commands. Successful exploitation grants attackers remote server control. *Remediation:* validate all inputs rigorously and eliminate unnecessary shell command execution.

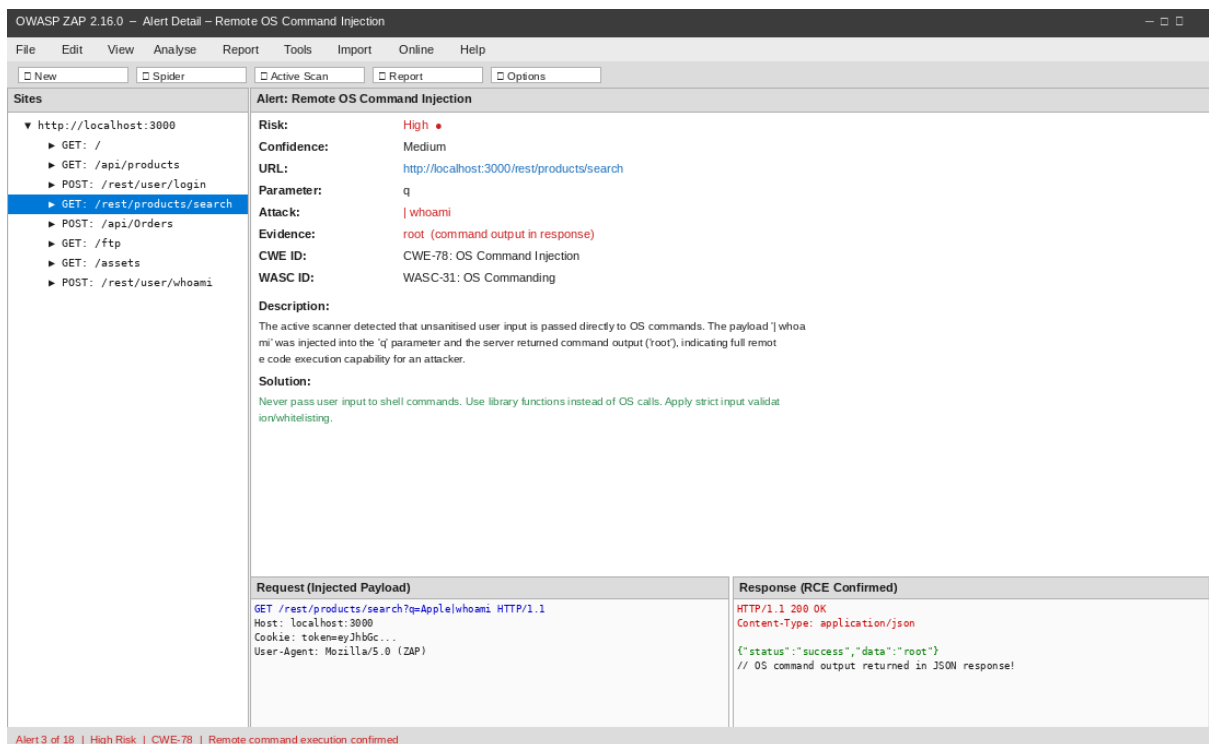


Figure 8: ZAP Active Scanner — OS Command Injection (High Risk, CWE-78); 'root' returned in response

Conclusion

The vulnerabilities identified present significant risks to SecureMart Ltd.'s customer data and business operations. Prompt remediation aligned with OWASP guidelines is recommended to reduce the attack surface and ensure regulatory compliance.

References

- OWASP Foundation. (2021). *OWASP Top Ten*. <https://owasp.org/www-project-top-ten/>
- OWASP Foundation. (2023a). *OWASP ZAP — The world's most widely used web app scanner*. <https://www.zaproxy.org/>
- OWASP Foundation. (2023b). *OWASP Juice Shop*. <https://owasp.org/www-project-juice-shop/>
- Stuttard, D., & Pinto, M. (2011). *The web application hacker's handbook: Finding and exploiting security flaws* (2nd ed.). Wiley.